

Code Review: Issue Backlog & Fix Checklist

Prioritised by risk and impact

Security First (Highest Risk)

1. Stop Leaking Password Hashes

- **File:** accounts/serializers.py
- Remove `password` from `UserSerializer.fields` — currently included, so any endpoint returning `UserSerializer` can expose hashes.
- **Tests:** Request user-related endpoints and assert the response body never contains `password`.

2. Prevent Non-Voters from Crashing the Voter Profile Endpoint

- **File:** accounts/views.py (`VoterProfileView`)
- Restrict access so only users with `role=voter` (or `is_voter_user`) can reach the view, and return 404 (or 403) if no `voter_profile` exists.
- **Tests:** Authenticate as admin/election officer and call the voter profile route; expect 403/404, not 500.

3. Lock "Verify Voter" Admin Actions Strictly to Voter Users

- **File:** accounts/services.py (`VoterManagementService.verify, verify_all_pending`)
- Ensure `verify()` only updates users with `role=VOTER` (and `is_active=True`).
- Ensure `verify_all_pending()` only flips `is_verified=False` for voter-role users — currently updates ALL unverified users, including admins/staff.
- **Tests:** Create an unverified admin + unverified voter; verify-all should only verify voters.

Vote-Casting Stability (Core Functionality Reliability)

4. Enforce Request Consistency: `candidate_id` Must Exist When Not Abstaining

- **Files:** voting/serializers.py, voting/services.py
- Update serializer validation:
 - If `abstain == False` then `candidate_id` is required (not null/omitted).
 - If `abstain == True` then `candidate_id` is not allowed (or is forced to null).
- Prevents `KeyError` / invalid `Vote` rows and avoids 500s in `VoteCastingService.cast`.

5. Harden Error Handling in the Cast-Vote API

- **File:** voting/views.py (`CastVoteView.post`)
- Expand exception handling beyond `ValueError` and `Poll.DoesNotExist` to include common DB/runtime failures (e.g. `PollPosition.DoesNotExist`, `IntegrityError` from unique constraints), returning clean 400 responses.
- **Tests:**
 - Cast with invalid `poll_position_id`.

- Cast with invalid `candidate_id`.
- Cast duplicate vote (unique constraint) — expect 400, not 500.

6. Convert "Missing Related Objects" into Controlled Validation Errors

- **File:** `voting/services.py` (`VoteCastingService.cast`)
- Where it currently does `PollPosition.objects.get(...)` inside the loop, ensure 'not found' becomes a `ValueError` with a user-safe message so the view can consistently return 400.

Data-Rule Correctness (Logic / Meaning Issues)

7. Fix Audit Action Type for Draft Opening

- **File:** `elections/services.py` (`PollService.toggle_status`)
- The audit `log_action` is computed after `poll.status` is mutated, so 'open draft' gets logged incorrectly.
- **Tests:** Toggle from `DRAFT` → `OPEN` and assert the audit `action` is the expected one.

8. Prevent Opening Polls with Empty Candidate Sets per Position

- **File:** `elections/services.py` (`PollService.toggle_status`)
- Currently checks 'any poll position has candidates' rather than ensuring every ballot position has candidates.
- Decide the intended rule (usually: every position must have candidates) and enforce it.
- **Tests:** Open a draft poll where one position has candidates and another has none; expect 400.

9. Correct `max_winners` Validation

- **File:** `elections/serializers.py`
- `validate_max_winners` message says 'at least 1' but logic allows 0 (it checks `< 0`).
- **Tests:** Creating/updating a position with `max_winners=0` should be rejected.

10. Ensure Poll Creation Only Accepts Active Positions

- **File:** `elections/serializers.py` (`PollCreateSerializer.validate`)
- Validates position IDs exist but doesn't ensure positions are active (`is_active=True`).
- **Tests:** Create poll including an inactive position — expect 400.

11. Fix Age Validation to Be Date-Accurate

- **Files:** `accounts/serializers.py`, `elections/serializers.py`
- Both candidate and voter age validation currently uses `today.year - value.year` only — can be off by up to ~1 year around birthdays.
- Replace with the same month/day-aware logic used by `VoterProfile.age` / `Candidate.age`.
- **Tests:** Edge cases near birthdays.